SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min Total Marks: 50

Code of Conduct:

I **J. SAI DHEERAJ (192311191)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **J. SAI DHEERAJ**

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain tesla.com using theHarvester in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. (20 Marks)

1.1 Aim

To perform an Open-Source Intelligence (OSINT) assessment of the domain tesla.com using theHarvester in Kali Linux, identify publicly exposed email addresses and infrastructure information, assess social engineering risks, and recommend security countermeasures.

1.2 Tools required

- Kali Linux
- theHarvester
- Terminal
- Supported public search engines or OSINT data sources
- Screenshot utility in Kali Linux

1.3 Procedure and commands

Step 1: Open the Kali Linux terminal.

Step 2: Check whether theHarvester is installed.

theHarvester -h

If it is not installed, consult the Kali package manager documentation and install the available package.

Step 3: Review the available search sources.

theHarvester -h

Choose a source supported by your installed version. Some sources require API keys.

Step 4: Run a limited passive collection against the domain.

theHarvester -d tesla.com -b duckduckgo -l 100

Here:

- -d tesla.com specifies the target domain.
- -b duckduckgo selects the search source, if supported by the installed version.
- -l 100 limits the number of results requested.

The precise supported options and available results depend on the installed version and source configuration. Use the help output if the source is unavailable.

Step 5: Record the actual results in your report. Do not assume that the tool will find a particular number of addresses, hosts, or IPs.

Step 6: Capture a screenshot of the command and its output. If the output is long, capture additional screenshots showing the relevant sections.

1.4 Findings and email categorization

Enter only the email addresses and infrastructure details actually returned by the tool. Do not fabricate results.

Category	Indicators to look for	Security concern
Support	support@..., help@...	Fake support requests and impersonation
Sales	sales@..., info@...	Fraudulent quotations and business email scams
Human Resources	hr@..., careers@...	Fake recruitment messages and malicious CV attachments
Administration	admin@..., office@...	Impersonation of administrative personnel
Technical Teams	it@..., security@..., devops@...	Fake IT alerts, password-reset lures, and technical impersonation

These are role-based patterns, not verified Tesla email addresses. Classify an address only when the actual result or a reliable public source supports that classification. An address's name alone does not prove that the mailbox exists or belongs to a particular department.

Findings table for your lab submission

Information collected	Actual result
Domain assessed	tesla.com
Email addresses found	Enter observed count
Subdomains found	Enter observed count
Hosts found	Enter observed count
IP addresses found	Enter observed count
Data sources used	Enter actual sources
Assessment date	Enter date of execution

1.5 How attackers could misuse OSINT findings

1. Spear-phishing

Attackers can tailor deceptive messages to an apparent department or business function. A message referring to a publicly documented project or a known support process may appear more credible.

2. Credential harvesting

A fraudulent login page may be presented as a password-reset or account-verification page. If employees trust the message, they may disclose credentials.

3. Impersonation

Public job titles, department names, and contact details can be used to make a fraudulent message appear to come from HR, IT support, or management.

4. Infrastructure reconnaissance

Subdomains, hostnames, and IP addresses can reveal publicly visible services and help an attacker understand the organization's external attack surface.

1.6 Countermeasures

1. Email authentication: Configure SPF, DKIM, and DMARC to reduce domain spoofing.
2. Employee awareness: Conduct regular phishing awareness training and simulated exercises.

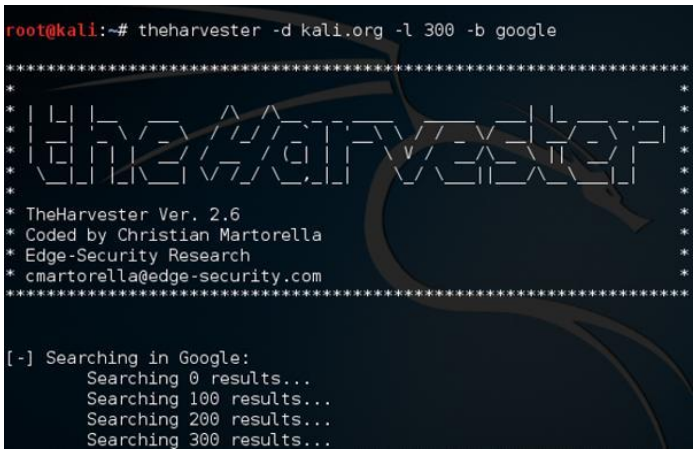
3. Information minimization: Avoid publishing unnecessary employee contact information, internal naming conventions, or infrastructure details.
4. Multi-factor authentication: Use phishing-resistant MFA, such as passkeys or security keys, for important accounts.
5. Email filtering: Use spam filtering, malicious URL detection, and attachment sandboxing.
6. Access control: Apply least privilege and limit access to sensitive internal systems.
7. Monitoring: Monitor suspicious sign-in activity, email forwarding rules, and attempted account takeovers.
8. Incident reporting: Provide a simple way for employees to report suspicious messages and respond quickly to suspected compromises.

1.7 Screenshots to attach



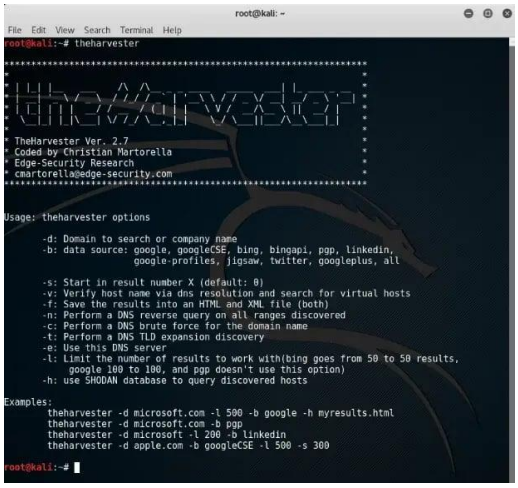
Screenshot 1 — Tool execution

Show the Kali Linux terminal, the command executed, and the actual theHarvester output.



Screenshot 2 — Discovered information

Capture the observed email addresses, hostnames, subdomains, or IP addresses. Redact sensitive details if required by your lab policy.



Screenshot 3 — Command and source verification

Show the supported command options or the selected data source where relevant.

These are visual references only, not evidence of a completed scan. Use screenshots from your own terminal in the submitted report.

1.8 Conclusion

TheHarvester can help identify publicly indexed email addresses, subdomains, and host information. This information can increase the risk of targeted phishing, impersonation, and infrastructure reconnaissance. Data minimization, email authentication, MFA, employee education, and continuous monitoring help reduce these risks.

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.(20 Mark).

2.1 Aim

To conduct an authorized phishing awareness simulation using GoPhish and dummy employee accounts, measure delivery, open, and click rates, and recommend measures to improve employee awareness.

2.2 Tools required

- GoPhish
- Authorized lab email server or SMTP test service
- Dummy employee email accounts
- Web browser
- Spreadsheet or report template

2.3 Procedure

Step 1 — Configure GoPhish

Set up GoPhish in the authorized lab. Access the administration interface and configure a test SMTP service. Protect the administration interface and credentials.

Step 2 — Create dummy recipients

Add the dummy employee accounts supplied by the instructor. Verify that all recipients are controlled by the lab.

Step 3 — Create an email template

Use a clearly controlled training scenario. Avoid collecting real passwords or sensitive personal information.

Step 4 — Configure the landing page

Use a training page that records a simulated interaction without accepting or storing actual credentials. Display an educational message after the test interaction.

Step 5 — Launch the campaign

Select the approved dummy recipient group, email template, landing page, and sending profile. Confirm that the campaign is authorized before sending.

Step 6 — Monitor results

Review the campaign dashboard for delivery events, email opens, clicks, and any other metrics supported by your setup. Export or record the results.

2.4 Sample phishing simulation email

The following is a safe template for a controlled training exercise. Replace the organization name and link with lab-approved values.

Hello Team,

As part of our organization's security awareness program, you may receive simulated emails designed to help identify common phishing indicators.

Please review the sender's address, check the destination of any links, and verify unexpected requests through an official communication channel.

If you identify a suspicious message, report it to the IT security team.

Thank you,
Security Awareness Team

Training exercise: This message is part of an authorized security awareness activity.

For a realistic awareness test, your instructor may provide an approved simulated phishing template. Keep it restricted to the dummy accounts and ensure that the landing page does not collect real passwords.

2.5 Calculating campaign metrics

Use the following formulas to analyze the GoPhish report.

$$\text{Delivery Rate} = \frac{\text{Emails Delivered}}{\text{Emails Sent}}\times100$$

$$\text{Open Rate} = \frac{\text{Unique Opens}}{\text{Emails Delivered}}\times100$$

$$\text{Click Rate} = \frac{\text{Unique Clicks}}{\text{Emails Delivered}}\times100$$

Open tracking may be affected by image blocking and automated email scanners. Click tracking can also be affected by security tools, so these metrics should not be treated as perfect measurements of human behavior.

Example results (illustrative only)

Assume a campaign sends 100 emails, 95 are delivered, 60 have recorded opens, and 25 have recorded clicks.

Delivery rate

95%

95 / 100

Open rate

63.2%

60 / 95

Click rate

26.3%

25 / 95

Illustrative calculations only — replace these values with the actual campaign results.

2.6 Campaign report template

Metric	Actual result
Total emails sent	Enter count
Emails delivered	Enter count
Emails bounced	Enter count
Unique opens	Enter count
Unique clicks	Enter count
Delivery rate	Calculate percentage
Open rate	Calculate percentage
Click rate	Calculate percentage
Users who reported the email	Enter count, if measured

2.7 Recommendations to improve awareness

- Conduct short, regular phishing awareness sessions.
- Teach employees to verify sender identities and suspicious links.
- Encourage employees to report suspicious emails without fear of punishment.
- Enable MFA, preferably phishing-resistant MFA.
- Deploy email authentication, URL filtering, and attachment scanning.
- Repeat controlled phishing simulations and compare results over time.
- Provide targeted education to groups needing additional support.
- Follow an incident-response process for genuine credential exposure.

2.8 Conclusion

GoPhish enables organizations to measure how employees interact with simulated phishing emails. Delivery, open, and click rates help identify areas for improvement. Combining simulations with education, strong authentication, email filtering, and clear reporting procedures strengthens the organization's human security defenses.

3. Using Nmap Aggressive Scan (-A) on scanme.nmap.org, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack ethodology

and defensive recommendations.(10 Marks)

3.1 Aim

To perform an authorized Nmap aggressive scan of scanme.nmap.org, review its exposed ports and service information, and explain how reconnaissance findings may increase social engineering risks.

3.2 Command

On Kali Linux, run:

nmap -A scanme.nmap.org

The -A option enables several detection features, including:

- OS detection, where possible.
- Service and version detection.
- Default Nmap scripting engine (NSE) scripts.
- Traceroute.

Only scan the designated host within the Nmap project's permitted usage. Avoid denial-of-service tests, exploitation, or excessive scanning.

For a saved report, use:

nmap -A -oN nmap_report.txt scanme.nmap.org

The -oN option saves the normal text output to nmap_report.txt.

3.3 Report findings

Record the actual output from your scan.

Field	What to record
Target	scanme.nmap.org

Open ports	Actual port numbers shown
Services	Service names reported
Service versions	Detected versions, if available
OS detection	Detected OS or estimated OS
Scan limitations	Filtered ports, uncertain detections, or incomplete results

Do not assume a particular port or operating system will be found. Results can vary with time, network conditions, and the target's configuration.

3.4 Social engineering risk analysis

An attacker who obtains network scan results may use the findings to make fraudulent communication appear technically credible.

Example scenario: An attacker impersonates an IT support employee and sends a message claiming that a server or application requires urgent maintenance.

1. Reconnaissance: Public information and authorized scan results may reveal service names and technologies.
2. Pretext development: The attacker creates a plausible but false story about a software update or service interruption.
3. Impersonation attempt: The attacker pretends to be IT support and asks an employee to follow a link or disclose sensitive information.
4. Potential impact: If the employee trusts the request, credentials could be disclosed or a malicious attachment could be opened.

The scan does not reveal employees' identities or prove that a system is vulnerable. The social engineering scenario describes a possible misuse of technical information, not a demonstrated attack.

3.5 Defensive recommendations

1. Reduce information exposure: Avoid publishing unnecessary server banners and internal infrastructure details.
2. Patch systems: Keep operating systems, applications, and network services updated.
3. Restrict access: Use firewalls to limit management services to authorized networks.
4. Strengthen authentication: Use MFA and unique credentials for administrative accounts.
5. Verify IT requests: Require employees to confirm unusual requests through official channels.

6. Conduct awareness training: Teach staff to recognize fake IT alerts, urgent requests, and fraudulent login pages.
7. Monitor activity: Collect logs and alert on suspicious access attempts and unusual sign-ins.
8. Perform regular assessments: Use authorized scans to identify exposed services and remediate unnecessary exposure.

3.6 Conclusion

Nmap aggressive scanning can reveal useful information about exposed services, software versions, and possible operating systems. Attackers may use such information to develop believable IT support impersonation scenarios. Restricting network access, maintaining secure configurations, strengthening authentication, and training employees can reduce the associated risks.